

grt-proc-003298-data-subject-requests-davarav1

policies/global/grt-proc-003298-data-subject-requests-davarav1.docm

Objective

The objective of this document is to ensure that data subject requests are handled timely and accurately in terms of arts. 15 to 21 GDPR.

Scope

This procedure applies to all Grünenthal employees in the Grünenthal Headquarters. It also sets the principles and standards for all local SOPs in the Grünenthal affiliates, in line with all applicable data privacy laws.

This procedure replaces SOP nr. HQ-CM-070-0007-01 "Subject Rights Data Protection: Data Access Requests".

Responsibilities

This section provides information about the concerned roles in the described process.

Role

Responsibility

Employees

Forward immediately any requests from individuals who wish to exercise their data privacy rights to the Global Data Protection Officer and the German Data Protection Officer via dataprivacy.de@grunenthal.com

Global Data Protection Officer as representative of Global Compliance

Evaluates the characteristics of the data subject request and coordinates the execution of all measures that are required for the handling of data subject requests in close alignment with the German Data Protection Officer.

German Data Protection Officer (external)

Is the externally appointed Data Protection Officer for the Headquarters.

Evaluates the characteristics of the data subject request and coordinates the execution of all measures that are

required for the handling of data subject requests in close alignment with the Global Data Protection Officer.

Local Compliance Officer

Is the appointed Compliance Officer for the Grünenthal affiliate that processes personal data from the individual making the request, if applicable.

Assists the Global Data Protection Officer and the German Data Protection Officer in handling the data subject request.

Coordinates all actions necessary to handle the data subject request in the relevant affiliate.

Data Protection Coordinator

Is the appointed Data Protection Coordinator for the relevant HQ area that processes personal data from the data subject making the request.

Assists the Global Data Protection Officer and the German Data Protection Officer in handling the data subject request.

Coordinates all actions necessary to handle the data subject request in the relevant area.

Relevant area

Is the HQ area that processes personal data from the individual making the request.

Upon request of the Global Data Protection Officer and the German Data Protection Officer, provides details about the activities performed on the personal data of the data subject.

Executes the necessary actions to handle the data subject request with the assistance of the Data Protection Coordinator, and based on the instructions from the Global Data Protection Officer and the German Data Protection Officer.

Global IT

Supports and provides the general IT response (i. e. for the deletion of personal data from GRT systems).

Terms and Definitions

Terms

Definition/ Explanantion

CRM system

Customer Relationship Management system.

Data subject

Is a natural person who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person.

Data subject request

The enquiry from a natural person whose personal data is processed by GRT or a third party on behalf of GRT to exercise its data privacy rights in the context of such data processing.

Personal data

Is any information relating to an identified or identifiable natural person ('data subject'). The term "any information" concerns any type of data that can be attributed, directly or indirectly, to a natural person, such as name, age, profession, company position, personal or professional contact details, data concerning health, etc.

Data processing

Is any operation or set of operations which is performed on personal data or on sets of personal data, whether or not by automated means, such as collection, recording, organisation, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or destruction.

Data processor

Is a natural or legal person, public authority, agency or other body which processes personal data on behalf of GRT (i. e. payroll companies or cloud service providers).

GDPR

Is the General Data Protection Regulation 2016/679 that sets the standards for protecting personal data in the European Union and the European Economic Area market places.

Process

Receiving a data subject request

Individuals whose personal data is processed by GRT or by a third party on behalf of GRT (i. e. a data processor) may express the wish to exercise their data privacy rights (see 5.2). These are the so-called “data subject requests”.

Examples of personal data which is commonly processed by GRT or data processors on behalf of GRT are:

Personal data from job applicants

Employee data, such as name, address, bank account number or salary

Health data from clinical trial participants

Name and contact details of healthcare professionals

Contact details from vendors or customers

Any HQ employee may receive a request from a data subject. These requests may be received verbally or in writing.

Data privacy laws and GDPR in particular mandate that GRT handles the request and provides an answer to the data subject within one month upon receipt of the request.

Therefore, all requests must be immediately forwarded to the Global Data Protection Officer and the German Data Protection Officer (both via dataprivacy.de@grunenthal.com).

Types of data subject requests

Under the GDPR, individuals whose personal data is processed by GRT or by a data processor on behalf of GRT can exercise the following rights:

Data access requests: An individual requests to know the type of personal data GRT holds about him or her, the reasons why this data is processed by GRT and the means used by GRT when processing the personal data.

Data rectification requests: An individual enquires GRT to partially erase, amend or rectify inaccurate or incomplete personal data that GRT holds from him or her.

Data erasure requests: An individual requests GRT to delete all personal data that it holds from him or her.

Restriction of processing requests: An individual requests GRT to refrain from using his or her personal data during a certain period.

Data portability requests: An individual requests to receive from GRT the personal data that it has previously provided, in a structured, commonly used and machine-readable format. It also concerns cases where the individual requests GRT to transmit the personal data to another third party.

Objection requests: An individual requests GRT to stop processing his or her personal data, when GRT has justified such processing on the basis of its legitimate interests.

Whether a request from an individual falls under one or another of the previous categories will be assessed by the Global Data Protection Officer and the German Data Protection Officer.

Processing data subject requests

Upon being forwarded a request, the Global Data Protection Officer and the German Data Protection Officer will assess the characteristics of the request and will coordinate the execution of all measures that are required for handling it.

The Data Protection Coordinator responsible for the relevant area will assist the Global Data Protection Officer and the German Data Protection Officer and will coordinate all necessary actions to be performed by the area in order to handle the request.

When the data subject request concerns a GRT affiliate, the Local Compliance Officer will assist the Global Data Protection Officer and the German Data Protection Officer and will coordinate all necessary actions to be performed by the affiliate in order to handle the request.

Pre-assessing the identity of the data subject

The Global Data Protection Officer and the German Data Protection Officer must verify the identity of the individual

making the request.

When they have reasonable doubts about its identity, they must approach the requestor asking for confirmation.

Requests from third parties, such as attorneys or parents, on behalf of data subjects are acceptable, provided that the third party is in fact entitled to act on behalf of the requestor. In such cases, proof of such entitlement must be requested and retained by the Global Data Protection Officer and the German Data Protection Officer.

Confirmation of receipt

Upon receipt of a data subject request, the Global Data Protection Officer and the German Data Protection Officer must confirm the reception of the request by GRT to the data subject in writing.

As a general rule, the reply will be made using the same means used by the data subject when making the request, except when the request was made by phone or verbally, in which case a documented reply is required.

Keeping record of the data subject request

All requests will be entered by the Global Data Protection Officer and the German Data Protection Officer in the register of data subject requests.

The Global Data Protection Officer and the German Data Protection Officer will maintain and update the register as actions to handle the request are taken.

Evaluating the data subject request

The Global Data Protection Officer and the German Data Protection Officer will evaluate the characteristics of the request.

If necessary, they will require the relevant area to provide additional details about the activities performed on the personal data of the individual making the request, with the assistance of the Data Protection Coordinator (or the local Compliance Officer, in case an affiliate is involved).

Based on this assessment, the Global Data Protection Officer and the German Data Protection Officer will make a decision whether GRT must attend the demands from the data subject or if the request must be denied.

Processing accepted requests

When the Global Data Protection Officer and the German Data Protection Officer conclude that GRT must attend the demands from the data subject, they will provide the relevant area and the Data Protection Coordinator (or the local Compliance Officer, as appropriate) with clear instructions on the actions to be taken.

Depending on the type of request, the relevant area may be required to take the following actions concerning the personal data of the individual making the request:

Provide detailed information about the personal data it processes about this person.

Rectify or amend certain information.

Permanently delete parts or all information about this individual.

Stop using or processing certain personal data.

If necessary, the assistance of other areas may be required to satisfy the request (i. e. Global IT if certain data has to be deleted from GRT systems).

In addition, if the data was shared with other third parties, such as data processors, they must be informed about the request from the data subject to exercise its rights and the need for their collaboration. The Data Protection Coordinator (or the local Compliance Officer, as appropriate) must coordinate the communication with the data processor.

When processing the request, special attention will be paid to minimize the associated risks of the actions to be taken, such as using state-of-art encryption solutions to transfer data outside of GRT or making sure that confidential data remains as such.

In any case, the request must be processed without undue delay, so it is ensured that the required deadlines which are defined in the GDPR are met.

Handling denied requests

When the Global Data Protection Officer and the German Data Protection Officer conclude that a request from a data subject must not be answered, they will document their decision in the register of data subject requests as well as any other relevant documents supporting the decision, in line with data privacy laws.

Communicating the outcome to the data subject

After accepted requests are processed (i. e. personal data has been deleted or amended, as requested by the

data subject), the Global Data Protection Officer and the German Data Protection Officer will communicate the final outcome to the data subject.

Denied requests will also be communicated to the data subject, including the reasons for the denial and with the information about the right to lodge a complaint before a data protection authority.

In any case, the communication to the data subjects will be conducted by the Global Data Protection Officer and the German Data Protection, and it will be made no later than one month since the request was received by GRT. Any exceptions to this rule must be approved by them.

Making use of the additional two months period foreseen by the GDPR

In exceptional cases, and only when the Global Data Protection Officer and the German Data Protection Officer conclude that the complexity of the request makes it impossible for GRT to process the request within the one month period deadline, it may be acceptable to make use of an additional two months period defined in the GDPR to process the request.

The latter is also acceptable when GRT has received a considerable number of requests from the same individual.

In such cases, the Global Data Protection Officer and the German Data Protection Officer will communicate GRT's decision to extend the deadline to the data subject without undue delay.

Templates and forms required for the process

Template to confirm receipt of a data subject request.

Template to confirm identity of the individual making the request.

Template to communicate that the request was accepted and successfully processed by GRT.

Template to communicate that the request was denied.

Template to communicate that GRT makes use of the additional two months period.

References

Not applicable

Historical index

Revision no.

Description of changes

01

HQ-CM-070-0007-01 – replaced with this new version

8. Apéndice: México.

8.1 Objective

This Appendix aims to adapt the Global Policy governing data subjects' rights requests to comply with Mexican data protection regulations.

8.2.Scope

This Appendix and the procedures set forth herein shall apply when, due to the origin of the data, the effects of the processing, or any other criterion established under applicable law or international regulations, Mexican data protection legislation is deemed applicable.

This Appendix shall be complemented by the local policies on data subjects' rights adopted by GRT subsidiaries, particularly Grünenthal de México, S.A. de C.V., which further develop the roles, procedures, and methodologies necessary to ensure compliance with Mexican data protection regulations.

8.3. Responsibilities.

The section 3 Responsibilities of GRT's Global Policy is amended as follows

Employees: They shall no longer forward requests to the Global Data Protection Officer or the German Data Protection Officer. Instead, requests shall be sent to the Data Protection Team of the corresponding subsidiary and to the Mexican Data Protection Officer. For the Mexican subsidiary, requests shall be directed to Datos.PersonalesMX@grunenthal.com.

Subsidiary Data Protection Team (in Mexico referred to as the Data Protection Department): Assumes the

responsibilities of the Global Data Protection Officer, with the support of the Mexican Data Protection Officer.

Mexican Data Protection Officer: Instead of being an external professional appointed by headquarters, this role shall be assigned by the corresponding subsidiary. Its responsibilities remain the same but shall be carried out in coordination with the Data Protection Team.

Local Compliance Officer: Retains the same responsibilities but will assist the Data Protection Team and the Mexican Data Protection Officer.

Data Protection Coordinators: Maintain their responsibilities but shall support the Data Protection Team and the Mexican Data Protection Officer.

Relevant Area: Retains its functions but will be responsible for responding to requests from the Data Protection Team and the Mexican Data Protection Officer.

8.5. Process:

8.5.1. Receiving a data subject request.

The procedure established in section 5.1 Receiving a Data Subject Request shall be adopted in Mexico with the following modifications:

The response time set forth under the GDPR is eliminated. Instead, GRT shall have five (5) days to review the request and issue any observations (e.g., missing information, lack of identification, etc.) to ensure it meets the legal requirements. Once the request complies with all requirements, GRT shall have twenty (20) days to determine its admissibility, and if deemed valid, an additional fifteen (15) days to make it effective.

Instead of forwarding requests to the Global Data Protection Officer and the German Data Protection Officer, employees must immediately send data subject requests to the Data Protection Team of the corresponding subsidiary and to the Mexican Data Protection Officer

8.5.2. Types of Data request:

The rights recognized under Mexican data protection law are similar to those established in the Global Policy (European rights), but they differ in the following terms:

Data Access Request: Same as in Europe.

Data Rectification Request: Same as in Europe.

Data Erasure Request: In Mexico, this right is referred to as a Data Cancellation Request.

Data Restriction Request: Not recognized in Mexico.

Data Portability Request: Not recognized in Mexico.

Data Objection Request Similar to the Mexican equivalent, except that it does not require the processing to be based on the controller's legitimate interest.

Right to Withdraw Consent: Refers to the data subject's ability to revoke the consent previously granted for the processing of their personal data, without retroactive effect, except when GRT must continue processing due to a legal or contractual obligation.

8.5.3. Processing Data Subject Requests

The process established in the section "Processing Data Subject Requests" is applicable in Mexico; however, it shall be carried out by the Data Protection Team and the Mexican Data Protection Officer.

8.5.3.1. Pre-Assessing the Identity of the Data Subject

This process is applicable in Mexico with the following modifications:

It shall be carried out by the Data Protection Team and the Mexican Data Protection Officer.

To verify the requester's identity, the Data Subject must provide a copy of an official identification document.

8.5.3.2. Confirmation of Receipt

The process is applicable in Mexico; however, it shall be carried out by the Data Protection Team and the Mexican Data Protection Officer.

8.5.3.3. Keeping Record of the Data Subject Request

The process is applicable in Mexico; however, it shall be carried out by the Data Protection Team and the Mexican Data Protection Officer.

8.5.3.4. Evaluating the Data Subject Request

This process shall be adopted in Mexico with the following modifications:

The procedure shall be carried out by the Data Protection Team and the Mexican Data Protection Officer.

They shall have five (5) days to request additional information if the application does not meet the legal requirements or if the requested data cannot be identified.

Once all required information has been received, they shall have twenty (20) days to evaluate the request's admissibility.

8.5.3.5. Processing Accepted Requests

The processes established shall be adopted in Mexico with the following modifications:

The procedure shall be carried out by the Data Protection Team and the Mexican Data Protection Officer.

In addition to following the steps set forth in the Global Policy, they must notify the data subject of the acceptance of their request.

They shall have fifteen (15) days to make the accepted request effective.

8.5.3.6. Handling Denied Requests

The processes established shall be adopted in Mexico with the following modification:

The procedure shall be carried out by the Data Protection Team and the Mexican Data Protection Officer.

8.5.3.7. Communicating the Outcome to the Data Subject

The processes established shall be adopted in Mexico with the following modifications:

The procedure shall be carried out by the Data Protection Team and the Mexican Data Protection Officer.

Notification of the acceptance or denial of the request must be provided within twenty (20) days from the date the request was received, or from the date additional information was received, as applicable.

8.5.3.8. Extension

The section 5.3.8 Making Use of the Additional Two-Month Period Foreseen by the GDPR is not applicable in Mexico. However, Mexican regulations allow the Data Protection Team and the Mexican Data Protection Officer to extend, when deemed necessary and justified, the 20-day period for determining the admissibility of a request and the 15-day period for making it effective, each for an additional equivalent period. Such an extension must be duly communicated to the data subject.

8.5.4. Templates and forms required for the process

In addition to the templates and forms already required, the following document shall also be necessary for implementation:

Manual for the Attention of ARCO Rights of Grünenthal de México, S.A. de C.V., GRT's subsidiary in the region.